

HiveForce Labs

THREAT ADVISORY



VULNERABILITY REPORT

Multiple Flaws in Citrix NetScaler ADC and Gateway Pose Immediate Threat

Date of Publication

June 27, 2025

Admiralty Code

A1

TA Number

TA2025202

Summary

First Seen: June 2025

Affected Product: Citrix NetScaler ADC and NetScaler Gateway

Impact: Recent Citrix NetScaler vulnerabilities, including CVE-2025-6543 (memory overflow) and CVE-2025-5777 (CitrixBleed 2), pose critical risks like DoS, session hijacking, and MFA bypass. CVE-2025-6543 is already being exploited in the wild, while CVE-2025-5777 is expected to be weaponized soon. Affected versions include NetScaler ADC/Gateway prior to 14.1-47.46 and 13.1-59.19, as well as all EOL versions, including 12.1 and 13.0. Urgent patching and post-update session termination are strongly recommended.

CVEs

CVE	NAME	AFFECTED PRODUCT	ZERO-DAY	CISA KEV	PATCH
CVE-2025-6543	Citrix NetScaler ADC and NetScaler Gateway Buffer Overflow Vulnerability	Citrix NetScaler ADC and NetScaler Gateway			
CVE-2025-5777	CitrixBleed 2 (Citrix NetScaler Gateway Out-of-Bounds Read Vulnerability)	Citrix NetScaler ADC and NetScaler Gateway			
CVE-2025-5349	Citrix NetScaler ADC and NetScaler Gateway Improper Access Control Vulnerability	Citrix NetScaler ADC and NetScaler Gateway			

Vulnerability Details

#1

Recently, critical vulnerabilities have been identified in NetScaler ADC and Gateway appliances, most notably CVE-2025-6543, a memory overflow flaw with a CVSS score of 9.2. This vulnerability has already been observed in active attacks, primarily resulting in denial of service but with the potential for more severe outcomes, such as unauthorized code execution. It affects appliances configured as VPNs, ICA proxies, CVPNs, RDP proxies, or AAA servers running versions prior to 14.1-47.46, 13.1-59.19, and all unsupported 12.1 and 13.0 releases.

#2

Another major issue, CVE-2025-5777 (dubbed “CitrixBleed 2”), is a critical out-of-bounds read vulnerability (CVSS 9.3) that could allow attackers to extract session tokens from memory. This enables session hijacking and bypass of multi-factor authentication, echoing the notorious 2023 [CitrixBleed](#) incident. While there are no reports of active exploitation yet, the severity and nature of the flaw make it highly attractive to threat actors.

#3

Citrix has also addressed CVE-2025-5349, a high-severity improper access control vulnerability in the management interface. Updated fixes for all three vulnerabilities are available in builds 14.1-47.46 and later, 13.1-59.19 and later, as well as their respective FIPS/NDcPP variants. Appliances running unsupported versions (12.1 and 13.0) remain exposed and should be upgraded or decommissioned immediately.

Vulnerabilities

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2025-6543	NetScaler ADC and NetScaler Gateway 14.1 BEFORE 14.1-47.46, 13.1 BEFORE 13.1-59.19 NetScaler ADC 13.1-FIPS and NDcPP BEFORE 13.1-37.236-FIPS and NDcPP	cpe:2.3:a:citrix:netcaler_application_delivery_controller:*:*:*:*:*:* cpe:2.3:a:citrix:netcaler_gateway:*:*:*:*:*:* cpe:2.3:a:citrix:netcaler_application_delivery_controller:*:*:*:*:fips:*:* cpe:2.3:a:citrix:netcaler_application_delivery_controller:*:*:*:*:ndcpp:*:*	CWE-119

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2025-5777	NetScaler ADC and NetScaler Gateway 14.1 BEFORE 14.1-43.56, 13.1 BEFORE 13.1-58.32	cpe:2.3:a:citrix:netscaler_application_delivery_controller:*:*:*:*:*:* cpe:2.3:a:citrix:netscaler_gateway:*:*:*:*:*:* cpe:2.3:a:citrix:netscaler_application_delivery_controller:*:*:*:*:*:*	CWE-125
CVE-2025-5349	NetScaler ADC 13.1-FIPS and NDcPP BEFORE 13.1-37.235-FIPS and NDcPP NetScaler ADC 12.1-FIPS BEFORE 12.1-55.328-FIPS	cpe:2.3:a:citrix:netscaler_application_delivery_controller:*:*:*:*:*:*:fips:*:*:* cpe:2.3:a:citrix:netscaler_application_delivery_controller:*:*:*:*:*:*:ndcpp:*:*:*	CWE-284

Recommendations



Apply Security Updates Immediately: Organizations must prioritize patching all customer-managed Citrix NetScaler ADC and Gateway appliances to secure versions. The affected versions include 14.1 (before 14.1-47.46), 13.1 (before 13.1-59.19), and 13.1 FIPS/NDcPP (before 13.1-37.236). Appliances running 12.1 or 13.0 should be decommissioned, as these versions are End-of-Life and will not receive patches.



Terminate Active Sessions Post-Patch: After patching, proactively kill all active ICA and PCoIP sessions to invalidate potentially compromised session tokens:

- kill icaconnection –all
- kill pcoipConnection –all

This ensures that any existing session tokens potentially exposed prior to patching are invalidated.



Restrict Internet Exposure: Public-facing NetScaler appliances are the primary attack surface for this vulnerability. Wherever possible, restrict external access using VPNs, firewalls, or segmentation strategies. Limit access to management interfaces and authentication services (e.g., AAA virtual servers) to trusted IP ranges only.



Implement Defense-in-Depth Controls: Apply layered security measures to reduce risk even if exploitation occurs. This includes enforcing least privilege on all administrative interfaces, using strong authentication methods, and segregating NetScaler systems from high-value targets within the network. Log access to all NetScaler interfaces for audit and alerting purposes.



Potential MITRE ATT&CK TTPs

<u>TA0003</u> Persistence	<u>TA0042</u> Resource Development	<u>TA0001</u> Initial Access	<u>TA0040</u> Impact
<u>TA0002</u> Execution	<u>TA0004</u> Privilege Escalation	<u>TA0006</u> Credential Access	<u>T1588.005</u> Exploits
<u>T1588.006</u> Vulnerabilities	<u>T1068</u> Exploitation for Privilege Escalation	<u>T1203</u> Exploitation for Client Execution	<u>T1059</u> Command and Scripting Interpreter
<u>T1556</u> Modify Authentication Process	<u>T1190</u> Exploit Public-Facing Application	<u>T1588</u> Obtain Capabilities	<u>T1498</u> Network Denial of Service



Patch Links

<https://support.citrix.com/support-home/kbsearch/article?articleNumber=CTX694788>

<https://support.citrix.com/support-home/kbsearch/article?articleNumber=CTX693420>



References

<https://www.fortiguard.com/threat-signal-report/6134/citrix-netscaler-adc-and-netscaler-gateway-vulnerabilities>

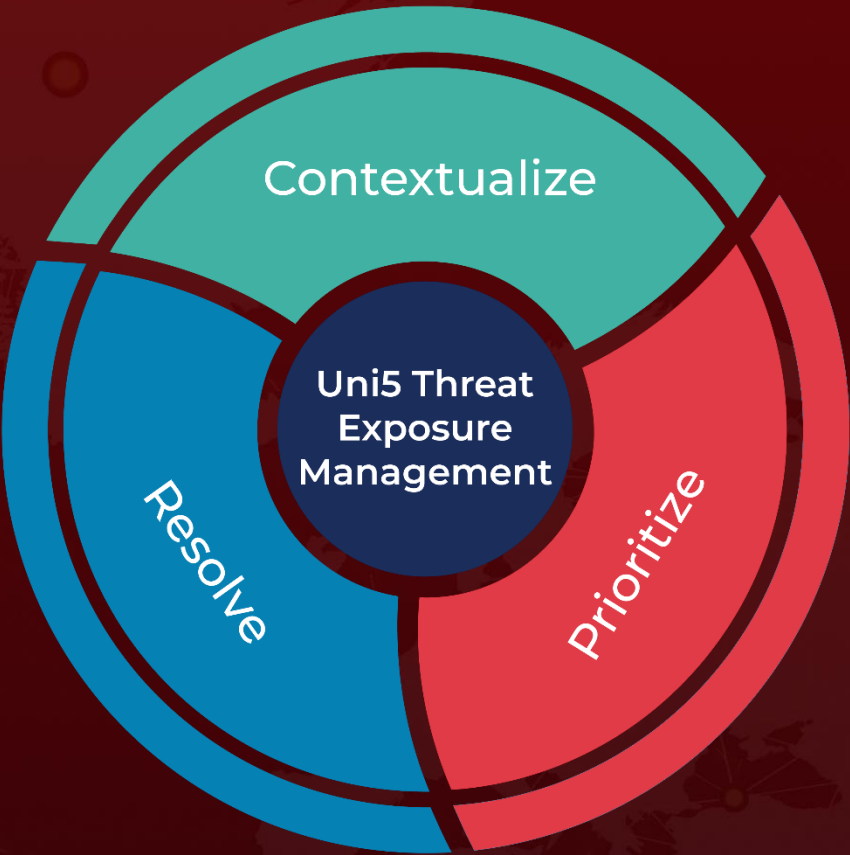
<https://www.hivepro.com/threat-advisory/a-longstanding-zero-day-in-citrix-devices-exploited-since-august/>



What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON
June 27, 2025 • 7:30 AM

